

Security Auditing & Digital Forensics

Mock Exams — Probable Questions (groups of four)

University of Coimbra — MSI/MEI — 2025/2026

Practice papers in the format of the real exam

About these papers. The real exam is **open book**, lasts $\approx 60+15$ minutes and is worth **6 points** split over **four short, applied questions** (1.5 pts each). Below are **six** complete mock papers, each a balanced group of four questions sampling the whole syllabus (compliance + forensics). Sit one under timed conditions, then check yourself against the **Solution Sketches** at the end (Appendix). Detailed model answers for the underlying concepts are in the companion *worksheet* Answer Key.

DEI – FCTUC | Master’s in Informatics Security (MSI/MEI)

Security Auditing — Mock Exam A

Open book • Quotation: 6 points • Duration: 60 m + 15 m

A computer may be used with all communication interfaces turned off. Each question is worth **1.5 points**.

1. Consider the ISO/IEC 27001:2022 control area **A.5.19–A.5.22 (Information security in supplier relationships)**. Give a concrete example of a control that contributes to this objective and justify how it reduces risk.
2. Describe the **four security controls** you consider most important for the **System/Application Domain** of an IT infrastructure, and justify your choice.
3. State the order of volatility (RFC 3227) from most to least volatile, and explain why an incident-response procedure that begins by “rebooting the server” destroys evidence.
4. Explain the main function of **ENISA** and the EU-level cooperation it supports, as established by EU Regulation 2019/881 (the Cybersecurity Act).

DEI – FCTUC | Master's in Informatics Security (MSI/MEI)

Security Auditing — Mock Exam B

Open book • Quotation: 6 points • Duration: 60 m + 15 m

A computer may be used with all communication interfaces turned off. Each question is worth **1.5 points**.

1. An organization must choose how to handle a risk it has identified. Name the **four risk-treatment options** and, for each, give one concrete example. State the condition under which *accepting* the risk is the rational choice.
2. Describe **two example situations** that illustrate the importance of a **Code of Ethics / deontology** in an IT security auditing or forensic process.
3. Explain the difference between a **logical copy** and a **physical bit-stream image** of a disk, and state two artifact types that only the bit-stream image captures.
4. Under NIS2, state the **incident-reporting timeline** an essential entity must follow and explain what it means for management to be “personally liable.”

DEI – FCTUC | Master's in Informatics Security (MSI/MEI)

Security Auditing — Mock Exam C

Open book • Quotation: 6 points • Duration: 60 m + 15 m

A computer may be used with all communication interfaces turned off. Each question is worth **1.5 points**.

1. ISO 27001 is described as the only *certifiable* standard of the family. Explain what an ISO 27001 certification actually attests, and how ISO 27002 relates to it (use one “Annex A vs. guidance” example).
2. A SIEM alerts on a suspicious PowerShell process on a critical Windows server that must stay online. Describe a **forensically-sound response** that preserves evidence while restoring service, naming the concrete steps and tools.
3. Explain the purpose of a **hardware write-blocker** and describe two things a Windows workstation would write to a suspect drive if it were simply plugged in without one.
4. Compare **NetFlow** and **full packet capture (PCAP)** on storage cost, retention and forensic use, and explain why “the network is harder to deceive” than the endpoint.

DEI – FCTUC | Master's in Informatics Security (MSI/MEI)

Security Auditing — Mock Exam D

Open book • Quotation: 6 points • Duration: 60 m + 15 m

A computer may be used with all communication interfaces turned off. Each question is worth **1.5 points**.

1. Explain the **shared-responsibility** model of ISO 27017 by stating, for a **SaaS** deployment, who controls the application, platform, virtual infrastructure and physical infrastructure — and contrast this with **IaaS**.
2. Name the **six functions** of the NIST Cybersecurity Framework 2.0, identify which one is new in version 2.0, and explain why it was added.
3. Explain the architectural change from **Volatility 2** to **Volatility 3** (profiles vs. symbols), and describe what the Volatility 3 “Automagic” component does.
4. State the GDPR breach-notification rule (Article 33) and the single condition under which notifying the affected individuals (Article 34) is *not* required.

DEI – FCTUC | Master's in Informatics Security (MSI/MEI)

Security Auditing — Mock Exam E

Open book • Quotation: 6 points • Duration: 60 m + 15 m

A computer may be used with all communication interfaces turned off. Each question is worth **1.5 points**.

1. Differentiate an **IT security assessment** from an **IT security audit**, giving two clear differences (consider attribution and consequences).
2. “Image-everything” forensics fails at enterprise scale. Explain the **Dead-Box fallacy** (three reasons) and describe what the **modern triage** approach does instead.
3. Explain what the `windows.malfind` plugin detects, and why finding an “MZ” header in the heap of `explorer.exe` is a strong indicator of compromise.
4. Explain how **DORA Article 13** links *forensic readiness* to regulatory compliance for financial entities, referring to the “speed of forensic analysis.”

DEI – FCTUC | Master's in Informatics Security (MSI/MEI)

Security Auditing — Mock Exam F

Open book • Quotation: 6 points • Duration: 60 m + 15 m

A computer may be used with all communication interfaces turned off. Each question is worth **1.5 points**.

1. Distinguish **configuration management** from **change management**, and list the five steps of the change-control process.
2. Name the **five pillars of forensic readiness**. For the **time-synchronization** pillar, explain why sub-second accuracy can determine whether evidence is admissible in court.
3. Compare **KAPE** and **Velociraptor** across architecture, speed and best use case, and explain what **VQL** contributes to investigating a fleet of 1,000 machines.
4. Differentiate **SOC 2 Type I** from **Type II**, and name the five Trust Services Criteria (stating which one is mandatory in every report).

Appendix — Solution Sketches

Condensed marking guidance. For full model answers, see the *worksheet* Answer Key.

Mock A

1. Security clauses + right-to-audit in supplier contracts, due-diligence before onboarding, ongoing monitoring of supplier services — the supply chain is a major attack vector, so the control forces and verifies supplier security. **2.** e.g. harden to baseline; privileged-access/least privilege (A.8.2/8.5); vulnerability management/patching (A.8.8); logging & monitoring (A.8.15/16) — justify each by the risk it removes. **3.** Registers/Cache → RAM → Network state → Disk; re-booting wipes the top three volatile layers (fileless malware, keys, live connections). **4.** ENISA = permanent EU cyber agency: threat-intel/best-practice exchange, CSIRT cooperation, incident-response readiness, EU certification schemes.

Mock B

1. Avoid (disable USB), Transfer (cyber insurance), Mitigate (firewall+IDS), Accept (tolerate minor risk); accept is rational when mitigation cost > expected loss and risk is within appetite. **2.** e.g. (i) evidence implicates the commissioning manager → objectivity/ independence; (ii) exposure to unrelated personal data → confidentiality / authorized scope. Ethics safeguards impartiality and the credibility/admissibility of findings. **3.** Logical = files the filesystem shows; bit-stream = sector-by-sector clone; only the bit-stream captures deleted files, unallocated/slack space, hidden partitions, partition tables. **4.** 24h early warning → 72h full report → 1-month final, to the national CSIRT/competent authority; “personally liable” = executives must approve/oversee measures, get training, and can face personal sanctions for negligence (fines up to €10M / 2% turnover).

Mock C

1. Certification attests a conforming *ISMS* (risk-based, documented, monitored, improving) — not perfect security. 27001 = what (Annex A: “access shall be controlled”); 27002 = how (MFA, RBAC, least privilege). **2.** Forensic-aware IR: alert triggers automated triage (Velociraptor/KAPE) for RAM+ artifacts; auto-snapshot (disk+RAM); hash (SHA-256) to immutable WORM with chain of custody; then restore from clean backup. Preserves ScriptBlock/AMSI evidence while meeting continuity. **3.** Write-blocker allows reads, drops writes, preserving the original; without it Windows writes System Volume Information, updates Last-Accessed timestamps, creates Thumbs.db. **4.** NetFlow = metadata, cheap, 12+ months, C2 tracing; PCAP = full packets, expensive, days/weeks, payload carving. Endpoints can lie (hidden processes) but the wire still carried the traffic.

Mock D

1. SaaS: provider controls application, platform, virtual *and* physical infra (customer only data/users). IaaS: customer controls application (shares platform); provider controls virtual + physical infra. Shared responsibility = duties split by service model (responsibility matrix). **2.** Govern (new in 2.0), Identify, Protect, Detect, Respond, Recover; Govern added to embed cybersecurity in leadership/strategy/risk & accountability (a board issue). **3.** Vol2 needed manual Profiles (KDBG); Vol3 uses on-the-fly Symbols (PDB→ISF). Automagic auto-detects OS, scans layers, handles DTB/CR3 address translation & configuration. **4.** Art.33: notify the supervisory authority ≤72h after becoming aware (nature, consequences, measures). Art.34: notifying individuals not required if data was protected (e.g. encrypted) or the high risk no longer materializes.

Mock E

1. Assessment = internal, non-attributive, improvement-focused; Audit = independent, pass/fail,

attributable, with penalties/consequences. **2.** Dead-box fallacy: high friction, huge storage (2TB=2TB $\times$ N hosts), misses volatile data. Triage = agents collect golden artifacts (\$MFT, Prefetch, Registry, logs) in <10 min, remotely & targeted. **3.** malfind flags RWX memory, unbacked pages and PE/“MZ” headers; an “MZ” in explorer.exe’s heap = a PE injected/mapped into it $\Rightarrow$ process injection/hollowing. **4.** Art.13 requires post-incident forensic analysis and judges the “quality and speed” of it; speed becomes a compliance metric, achievable only with forensic readiness (ready capability, retainer, immutable logs).

Mock F

1. Config mgmt = changes requested/evaluated/authorized + documented known-good state; change mgmt = tracks changes and detects unauthorized ones. Steps: identify/request $\rightarrow$ evaluate $\rightarrow$ decide $\rightarrow$ implement $\rightarrow$ monitor. **2.** Pillars: time sync, advanced logging, legal mandate, triage tools, trained first responders. Time sync: drifted clocks break cross-machine correlation and “exactly when” proof $\Rightarrow$ evidence can be thrown out; need NTP Stratum 1/2 sub-second. **3.** KAPE = ad-hoc/tool-based, fast per host, deep single-host dive; Velociraptor = agent-server/query-based, near-instant fleet hunting. VQL treats endpoints as SQL tables — push lightweight queries, not tools, to query 1,000 machines at once. **4.** Type I = design at a point in time; Type II = operating effectiveness over 3–12 months. TSC: Security (mandatory), Availability, Processing Integrity, Confidentiality, Privacy.

Six mock papers $\times$ four questions = 24 probable exam questions spanning T1–T10 + DORA/SOC2. Pair with the worksheet & cheatsheet for full preparation.